

Manual de respuesta

Fecha: 30/01/26

Divier Jácamo Álvarez

Parque metropolitano la libertad

En este caso desarrollare un manual de respuesta de ciberseguridad biomédica ante un ataque en la clínica mental los protocolos del antes durante y después de un ataque y como proceder a de forma correcta para evitar cometer errores

En este escenario, redactaré un manual detallado para lidiar con incidentes de ciberseguridad biomédica en caso de un ataque a la clínica psiquiátrica Detallando los procedimientos previos, durante y posteriores a un ciberataque, ademas de cómo reaccionar adecuadamente para evitar errores.

Manual para Procedimientos para Incidentes: Ciberseguridad Biomédica

1. FASE A: Preparación y Detección Temprana

El objetivo es hacer evidente lo invisible en los dispositivos médicos sin registrar.

Identificación en Red: Se debe crear una lista de vigilancia en FortiSIEM, con el fin de detectar cualquier nueva dirección MAC conectada a los conmutadores de los sectores de hospitalización.

Segmentación Lógica: En Stellar Cyber, asignar las IPs que identifique con tráfico HL7 dentro de un grupo de recursos críticos llamado CRITICO_PACIENTES.

Fortalecimiento L1: Hay que asegurar que SentinelOne funcione en modo Protección en todas las estaciones de enfermería y dispositivos que procesan ECG/EEG.

Verificación Legal: Asegurar el almacenamiento de registros que cumplan con la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales, algo esencial para mantener la acreditación del Ministerio de Salud.

2.FASE DURANTE Contención y Continuidad Médica

Si notáramos una conducta rara, imaginemos un Ransomware o un ataque al sistema de llamados de enfermería, es crucial actuar rápido

0 min Detección Una alerta de SentinelOne se enciende, reportando un ataque en el servidor de expedientes, así es.

5 min Aislamiento La movida, es activar el Network Isolate en S1 para el equipo problemático.

Priorizando siempre, si el equipo en cuestión maneja el monitoreo de signos vitales, no se debe aislarlo sin avisarle al personal de enfermería, vía radio o intercomunicador

10 min Contención de Red Hay que bloquear cualquier tráfico sospechoso hacia el Carro de Paro o los Sistemas de Llamado desde el Firewall FortiGate, es importante.

Comunicación Directa Notificar al Jefe de Guardia sobre el Sistema de monitoreo comprometido. Comiencen rondas físicas cada 15 minutos en los pabellones de internamiento.

FASE DESPUÉS Recuperación y Reporte.

Luego de neutralizar la amenaza, se tiene que garantizar la validez legal ante el Ministerio de Salud.

Restauración: Implementar la función Rollback de SentinelOne! Esto para devolver los archivos de los pacientes a su estado original antes del cifrado.

Análisis Forense L1: Se procede a extraer el reporte Timeline del incidente desde Stellar Cyber, esto para identificar el origen de la amenaza, como por ejemplo una memoria USB comprometida

Solución: Si un equipo médico se ve comprometido, se gestionará con el proveedor biomédico el cambio de credenciales de fábrica, lo que es muy importante.

Registro Legal: Los registros del sistema FortiSIEM se exportarán para probar que la información protegida de salud fue preservada, evitando así posibles sanciones regulatorias.

Referencias

Asamblea Legislativa de la República de Costa Rica. (2011, 5 de septiembre). *Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales (Ley No. 8968).*

Sistema Costarricense de Información Jurídica. www.pgrweb.go.cr

SentinelOne. (2024). *SentinelOne Complete: Protección, detección y respuesta ante amenazas (EDR).* es.sentinelone.com

Stellar Cyber. (2024). *Open XDR Platform: Visibilidad y respuesta en dispositivos médicos (IoMT).* stellarcyber.ai